قايمة تشيك

قايمة تشيك: الـ token والـ URL

أمان الـ tokens

الـ token اللي بيتحط في اللينك بيتسرب من أماكن محدش بيفكر فيها. القايمة دي بتمشي على كل مكان وإيه تعمله فيه.

ليه ده بيحصل

أي حاجة في الـ URL بتتعامل على إنها مش سرية: المتصفح والسيرفرات والأدوات بتسجلها عادي. فلو لينك تسجيل الدخول أو إعادة تعيين الباسورد أو دعوة فيه token، فهو متسجل في أماكن كتير.

المكان 1: تاريخ المتصفح

- الـ token في اللينك بيفضل في الـ history وفي الـ autocomplete.
- **اعمل:** أول ما الصفحة تفتح، خد الـ token من اللينك واستبدل الـ URL بنسخة نضيفة من غير token (history.replaceState في المتصفح).
- **اعمل:** خلي الـ token يُستخدم مرة واحدة وينتهي بسرعة، فحتى لو اتسجل ميفرقش.

المكان 2: الـ Referer

- لما الصفحة فيها لينك أو صورة من موقع تاني، المتصفح ممكن يبعت عنوان الصفحة كامل (بالـ token) للموقع ده.
- **اعمل:** حط `Referrer-Policy: no-referrer` على الصفحات اللي بتستقبل tokens.
- **اعمل:** متحطش سكريبتات أو صور من برّه في الصفحات دي.

المكان 3: أدوات تتبع الأخطاء والـ logs

- أدوات تتبع الأخطاء بتسجل الـ URL مع كل error، وكذلك الـ access logs.
- **اعمل:** اضبط الأداة تمسح الـ query parameters الحساسة (token، key، code) قبل ما التقرير يطلع.
- **اعمل:** افحص الـ logs القديمة وشوف لو فيها tokens صالحة لسه، وبدّلها.

المكان 4: اللينكات اللي بتتبعت

- الإيميل والشات بيعملوا preview للينك، ولما بيعملوه بيفتحوه، فممكن يستهلكوا token مرة واحدة قبل المستخدم.

- **اعمل:** خلي اللينك يفتح صفحة فيها زرار «تأكيد»، والـ token يتستهلك بالضغط على الزرار مش بفتح الصفحة.

البديل الأصلي

- ابعت الـ token في الـ `Authorization` header) أو في الـ body بـ POST، مش في الـ URL.
- لو لازم يكون في اللينك (إيميل مثلا)، خليه قصير العمر ولمرة واحدة.

قايمة تشيك

- [ ] مفيش token بيتبعت في الـ URL إلا لو مفيش بديل
- [ ] الصفحة بتنضف الـ URL أول ما تفتح
- [ ] `Referrer-Policy` متظبطة
- [ ] أداة تتبع الأخطاء بتمسح الـ parameters الحساسة
- [ ] الـ access logs مفيهاش tokens صالحة
- [ ] الـ token بينتهي بسرعة ويتستخدم مرة واحدة
- [ ] اللينك في الإيميل مبيتستهلكش بالـ preview

Ahmed Sherif Nabhan